DATA RETENTION AND DISPOSAL POLICY

POL-002 | Issued under the Information Management Framework

Document ID: POL-002
Version: 1.0 — DRAFT
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Chief Information Officer
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Data Retention and Disposal Policy
Document ID	POL-002
Version	1.0 — DRAFT
Status	Draft for Review
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Chief Information Officer
Custodian	Information Security / Legal
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	GDPR Art. 5(1)(e), SOX Section 802, 21 CFR Part 11, EU Annex 11, GxP, HIPAA, CCPA

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Policy establishes mandatory requirements for the retention and secure disposal of all data assets at [Company Name]. It ensures that data is kept for as long as it is required — by law, by regulation, or by legitimate business need — and is securely and verifiably destroyed at the end of that period.

Retaining data longer than necessary increases exposure to regulatory, legal, and reputational risk. Disposing of data too early creates compliance gaps, destroys evidence needed for regulatory inspections, and may constitute a breach of applicable law. This Policy sets the balance and provides a binding schedule that eliminates ambiguity.

> **GxP:** GxP records have absolute minimum retention periods defined by regulation. These are non-negotiable floors — no business decision, cost pressure, or internal policy exception may override them.

2. Scope

This Policy applies to:

- All data assets at [Company Name] in any format — electronic, paper, and other physical media
- All systems that store, process, or archive company data
- All employees, contractors, and third parties who create, hold, or manage company data
- All geographic locations and legal entities within the [Company Name] corporate group

Third parties who hold [Company Name] data under contract are subject to the retention and disposal requirements specified in their Data Processing Agreement or Technical Agreement. The Data Owner retains accountability for those obligations.

3. Policy Statement

All data assets must be:

- Assigned a retention period at the point of classification, in accordance with the retention schedule in Section 5
- Retained for no less than the minimum period specified — disposing of data before the minimum period is a compliance breach

- Retained for no longer than the maximum period specified — holding data beyond the maximum (without legal hold justification) is a regulatory breach under GDPR and other privacy laws
- Securely disposed of at the end of the retention period using approved methods defined in Section 7
- Subject to a legal hold process that suspends normal disposal obligations when litigation, investigation, or regulatory inspection is anticipated or active (Section 6)

Retention periods run from the date the record is closed, the transaction is complete, or the relevant triggering event occurs — not from the date the record was created, unless specified otherwise in Section 5.

4. Roles and Responsibilities

Role	Responsibility
Data Owner	Accountable for ensuring data in their domain is classified with a retention period and that disposal is triggered at the correct time. Approves retention exceptions within their domain.
Data Custodian (IT)	Implements technical retention controls (automated archival, deletion schedules, backup purging). Executes disposal actions and produces disposal certificates.
Legal / Compliance	Owns the legal hold process. Issues legal hold notices. Advises Data Owners on retention requirements arising from litigation, regulatory change, or inspection. Maintains the master legal hold register.
Information Security	Oversees secure disposal standards. Approves third-party disposal vendors. Reviews and updates this Policy annually. Monitors compliance with retention schedules.
Compliance / QA	Accountable for GxP record retention compliance. Advises on regulatory minimum periods. Reviews retention schedule for regulatory accuracy annually.
Records Management (where designated)	Coordinates retention schedule application across the organisation. Manages physical records archiving and disposal logistics.

5. Retention Schedule

The following schedule defines minimum and maximum retention periods by data category and regulatory driver. Where multiple regulations apply to the same data type, the longest minimum period governs. Legal hold overrides all periods — see Section 6.

NOTE: Retention periods shown are minimums required by regulation or policy. Data Owners may apply longer periods where a documented business justification exists and the DPO has confirmed no conflict with GDPR data minimisation obligations.

5.1 GxP and Regulated Research Records

Data Category	Regulatory Driver	Minimum Retention Period	Trigger Event	Notes
Batch manufacturing records	GMP (21 CFR 211.180)	1 year post-expiry of batch or 3 years post-manufacture (whichever is longer)	Batch release date	Must be available for regulatory inspection throughout retention period.
Clinical trial records (master file)	ICH E6(R2) / 21 CFR 312	15 years post-trial completion (or as specified in protocol)	Trial completion date	Electronic records: 21 CFR Part 11 compliant archive required.
Clinical trial — subject data	GDPR / ICH E6(R2)	25 years (EU trials) or as per protocol (minimum 15 years)	Trial completion date	Pseudonymisation required; re-identification key held separately.
Laboratory notebooks / raw data (GLP)	GLP (OECD / 21 CFR 58)	10 years post-study completion	Study completion date	Original or certified copy. Audit trail must be retained.
GMP validation records	GMP / 21 CFR 211	Life of product + 1 year	Product discontinuation	Includes IQ/OQ/PQ documentation and change control records.
CSV / CSA validation documentation	21 CFR Part 11 / EU Annex 11	Life of system + 5 years	System decommission	Full validation lifecycle documentation must be retained.
Regulatory submissions (IND, NDA, BLA, MAA)	21 CFR / EMA	Life of approval + 5 years (minimum)	Approval granted or	Includes all corresponde

Data Category	Regulatory Driver	Minimum Retention Period	Trigger Event	Notes
			withdrawn	nce, amendments , and agency responses.
Adverse event / pharmacovigilance records	21 CFR 314.81 / EU DIR 2001/83	10 years (EU); 5 years (US) post-marketing approval	MA grant date	Longer period may apply — confirm with Regulatory Affairs.
Audit trail records (GxP systems)	21 CFR Part 11 / EU Annex 11	Same as the record to which the audit trail relates	Per record type	Audit trail must be retained alongside the original record.

5.2 Financial and SOX Records

Data Category	Regulatory Driver	Minimum Retention Period	Trigger Event
Audited financial statements	SOX Section 802 / Companies Act	7 years	Financial year end
Audit workpapers and supporting records	SOX / PCAOB	7 years	Audit completion
General ledger, accounts payable/receivable	SOX / local tax law	7 years (US); varies by jurisdiction	Financial year end
Payroll records	Jurisdiction-specific (typically FLSA / local law)	7 years	Employment end or year end
Tax records	IRS / HMRC / local tax authority	7 years (US); 6 years (UK); varies	Financial year end
Board and committee minutes	Companies Act / Corporations law	Permanent	Date of meeting
Contracts and agreements	Commercial law / SOX	7 years post-expiry	Contract expiry
ITGC evidence (SOX controls)	SOX / PCAOB	7 years	Control testing completion

5.3 Human Resources and Employment Records

Data Category	Regulatory Driver	Minimum Retention Period	Trigger Event
Employee personnel file	Employment law / GDPR	7 years post-employment end	Employment end date
Recruitment records (unsuccessful candidates)	GDPR / Equal opportunities	6 months (EU); 1 year (US)	Decision date
Health and safety records	OSHA / local law	5–30 years (varies by type)	Incident/record date
Training and competency records	GxP / local law	3 years post-employment end (GxP staff: life of employment + 5 years)	Employment end date
Disciplinary records	Employment law / GDPR	6 years post-resolution	Resolution date

5.4 General Corporate and Operational Records

Data Category	Regulatory Driver	Minimum Retention Period	Trigger Event
Corporate governance documents (Articles, share register)	Companies Act	Permanent	Date of creation
Insurance policies and claims	Commercial / legal	7 years post-policy expiry	Policy expiry
IP records (patents, trademarks)	IP law	Life of IP + 7 years	IP expiry or disposal
Correspondence (material business)	Legal / SOX	7 years	Date of correspondence
IT system logs (security)	ISO 27001 / SOX	1 year minimum (Tier 1: 2 years)	Log creation date
IT system logs (GxP audit trail)	21 CFR Part 11	Per associated record type	Per associated record
Project records (non-regulated)	Business policy	5 years post-project close	Project closure date
Supplier / vendor contracts	Commercial law	7 years post-expiry	Contract expiry
Data processing agreements (DPAs)	GDPR Art. 28	Life of relationship + 5 years	Relationship end

5.5 Privacy and Data Subject Records

Data Category	Regulatory Driver	Minimum Retention Period	Trigger Event
Records of processing activities (ROPA)	GDPR Art. 30	Duration of processing + 3 years	Processing cessation
Data subject request records	GDPR / CCPA	3 years	Request completion
Consent records	GDPR Art. 7	Duration of consent + 3 years	Consent withdrawal or expiry
DPIA records	GDPR Art. 35	3 years post-processing cessation	Processing cessation
Breach notification records	GDPR Art. 33–34	5 years	Breach date

6. Legal Hold Process

A legal hold is a directive that suspends normal data disposal obligations for specified data assets or categories. It is triggered when litigation, a regulatory investigation, a regulatory inspection, or any other legal proceeding is anticipated, threatened, or active.

6.1 Triggering a Legal Hold

Legal holds are triggered by Legal / Compliance and must be issued in writing. Triggers include:

- Receipt of a litigation claim, demand letter, or regulatory investigation notice
- Internal identification of circumstances likely to result in litigation or regulatory action
- Notification of a regulatory inspection (GxP, SOX, privacy authority)
- A data breach triggering regulatory investigation
- A court order or equivalent legal directive

6.2 Legal Hold Obligations

Step	Action	Responsible
1	Legal / Compliance issues a written Legal Hold Notice identifying: the scope of data covered, the relevant systems and custodians, the reason for the hold, and the anticipated duration.	Legal / Compliance
2	All named Data Owners and Data Custodians acknowledge receipt of the Legal Hold Notice in writing within 2 business days.	Data Owner / IT
3	IT suspends automated deletion schedules, backup purging, and archival processes for all data within scope of the hold.	Data Custodian (IT)
4	Legal / Compliance records the hold in the Legal Hold Register, including all in-scope custodians and systems.	Legal / Compliance
5	Legal / Compliance reviews active holds quarterly and confirms whether each remains necessary.	Legal / Compliance
6	When the hold is lifted, Legal / Compliance issues a written release notice. Normal retention and disposal obligations resume — data that has exceeded its retention period must be disposed of promptly.	Legal / Compliance

IMPORTANT: Deleting or destroying data subject to a legal hold — even accidentally — may constitute spoliation of evidence and carry severe legal consequences. If in doubt, contact Legal before disposing of any data.

7. Secure Data Disposal

Data disposal must be secure, verifiable, and proportionate to the sensitivity of the data being destroyed. The following standards apply.

7.1 Approved Disposal Methods

Data Type	Sensitivity Tier	Approved Method
Electronic data — standard storage (HDD, SSD, USB)	Tier 1–2	NIST 800-88 compliant overwriting (minimum 3-pass) or degaussing. Certificate of destruction required.
Electronic data — standard storage (HDD, SSD, USB)	Tier 3–5	Physical destruction (shredding/disintegration to NIST 800-88 standards) by approved vendor. Certificate required.
Cloud / SaaS data	All tiers	Cryptographic erasure (key destruction) where overwriting is not possible. Vendor confirmation of deletion in writing required. Confirm DPA obligations met.
Backup media	All tiers	Same method as primary data per sensitivity tier. Backup purge schedule must align with retention schedule.
Paper documents	Tier 1–2	Cross-cut shredding (minimum DIN 66399 P-3 level).
Paper documents	Tier 3–5	Cross-cut shredding to DIN 66399 P-5 level by approved vendor. Certificate of destruction required.
Physical devices (servers, workstations)	All tiers	Degaussing + physical destruction or NIST 800-88 overwrite before any physical disposal or return to vendor. Certificate required.
GxP records — electronic	All tiers	Must not be destroyed before regulatory minimum retention period. Post-retention: same as electronic data by sensitivity tier. Disposal must be documented in the audit trail.

7.2 Disposal Evidence

A disposal certificate or equivalent written record must be produced for all data disposed of at Tier 3 or above, and for all GxP records regardless of sensitivity tier. Disposal records must be retained for 7 years.

Disposal certificates must include: date of disposal, description of data/media disposed of, method of disposal, name of person or vendor who carried out disposal, and signature or digital confirmation.

7.3 Third-Party Disposal Vendors

Third parties engaged to carry out data disposal must be pre-approved by Information Security and must provide: evidence of appropriate security certification (e.g., NAID AAA, ISO 27001), contractual agreement to [Company Name]'s disposal standards, and a certificate of destruction for each disposal event.

8. Exceptions

Requests to retain data beyond its maximum retention period (excluding legal holds) or to dispose of data before its minimum retention period must be submitted to Information Security in writing. The request must include:

- The data asset and classification
- The applicable retention period and the requested deviation
- The business or legal justification
- Confirmation from Legal / Compliance that the deviation does not breach applicable law

Exceptions require approval from the Data Owner, Information Security, and Legal / Compliance. No exception may result in disposal of GxP records before the regulatory minimum period, or in retention of personal data beyond what is justifiable under GDPR's data minimisation principle.

9. Non-Compliance

Non-compliance with this Policy may result in regulatory fines, legal liability, or disciplinary action. Specific risks include:

- Premature disposal of GxP records: potential regulatory action by FDA, EMA, or equivalent authority, including warning letters, import alerts, or marketing authorisation suspension
- Premature disposal of SOX records: potential SEC enforcement action and criminal liability under Sarbanes-Oxley Section 802
- Over-retention of personal data: regulatory fines under GDPR (up to 4% of global annual turnover) and equivalent privacy authorities
- Disposal of data subject to legal hold: potential contempt of court or spoliation sanctions

10. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework
POL-001	Data Classification Policy	Classification tier determines retention schedule row
POL-003	Data Integrity Policy	GxP record integrity must be maintained throughout retention period
EXC-001	Exception Management Policy and Register	Retention period exceptions (early disposal or extended retention) are governed by EXC-001; statutory retention obligations may make certain exceptions non-approvable; DPO and Legal review required for GDPR-scoped retention exceptions
POL-004	Privacy Policy	GDPR data minimisation principle constrains maximum retention of personal data
POL-005	System Classification Policy	System decommissioning triggers data disposal obligations
POL-012	Incident Response Policy	Breach events may trigger legal hold
POL-013	Third Party and Vendor Risk Policy	Third-party disposal vendor requirements
SOP-002	Data Retention and Disposal Process	Operationalises this Policy (planned)

11. Definitions

Term	Definition
Cryptographic Erasure	Destruction of encryption keys such that encrypted data is rendered permanently unreadable, used where physical overwriting of cloud-stored data is not possible.
Disposal Certificate	Written evidence confirming that a data asset or storage medium has been destroyed in accordance with approved methods, including date, method, and responsible party.
Legal Hold	A formal directive suspending normal data disposal obligations for specified data pending or in anticipation of litigation, regulatory investigation, or inspection.
Retention Period	The defined timeframe during which a data asset must be kept. Divided into a minimum (regulatory floor) and maximum (regulatory ceiling or business policy limit).
Trigger Event	The event that starts the clock on a retention period — typically record

Term	Definition
	closure, transaction completion, employment end, or equivalent.

— End of Document —

POL-002 v1.0 DRAFT | [Company Name] | CONFIDENTIAL